

The Agentic SOC

What happens when AI starts investigating incidents before humans do?

Security operations are moving from alert queues and manual pivots toward systems where specialized agents can triage, correlate, investigate, and - inside strict boundaries - act.

The opportunity is speed. The risk is handing speed to an untrusted decision-maker.



<6h

GTIG observed an attacker plan, build and execute an agent-enabled mass credential-harvesting campaign.

75%

Microsoft says internal task agents automate this share of phishing and malware investigations in live environments.

\$1.93M

IBM 2026: breach-cost savings associated with extensive use of AI and automation in security vs. none.

Core thesis

AI should absorb repetitive evidence gathering and bounded response. Humans should retain intent, judgment, exception handling, and accountability.

Why the SOC is becoming agentic

The traditional SOC assumes that a human analyst has enough time to open an alert, collect context, pivot across tools, decide what matters, and then respond. That assumption is weakening.

Attackers are beginning to compress multi-stage operations into hours. A SOC that spends hours merely assembling evidence starts the investigation already behind.

What "agentic SOC" actually means

Not a chatbot sitting beside a SIEM. It is an operating model where AI agents can pursue bounded goals: collect evidence, correlate signals, reason across identity, endpoints, cloud and email, recommend or execute pre-authorized actions, and learn from analyst feedback.

Microsoft describes two layers: deterministic policy-bound controls for high-confidence threats, and agents for analysis and coordination. Google similarly positions agents around detection engineering, triage, investigation, hunting and response.

Human vs. machine

Machines: volume, correlation, repetitive investigation, speed, evidence assembly.

Humans: business context, ambiguous trade-offs, novel adversary reasoning, escalation authority, accountability.

The goal is not "remove analysts." It is to move analysts from queue processing toward supervision, hunting, detection engineering and risk reduction.

The pressure is now measurable

3 min

Microsoft reports average disruption time for attacks such as ransomware using autonomous attack disruption.

99.99%

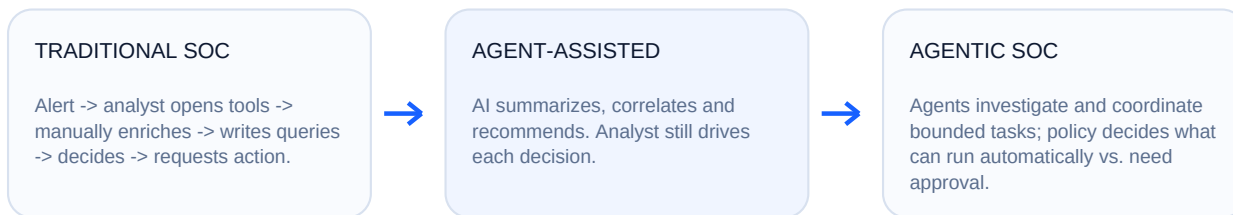
Microsoft-reported confidence rating for those high-confidence automated disruptions.

1 day -> <1h

Microsoft says an agent reduced a vulnerability-exposure assessment from a full engineering day to under an hour.

Interpret carefully: these are different workloads and vendor-reported measurements, not a direct benchmark. The common signal is what matters: security work that previously required human-scale time is increasingly being performed at machine-scale time.

The real shift: from alert handling to decision orchestration



Where the value appears first

Workload	Why it fits agents	Human checkpoint
Phishing / low-value triage	High volume, repetitive evidence collection, known verdict patterns.	Escalate uncertain or business-sensitive cases.
Incident enrichment	Cross-tool pivots, timeline reconstruction, IOC / identity / asset context.	Validate causality and incident scope.
Threat hunting	Generate hypotheses, queries, pivots and related entities quickly.	Analyst decides which hypotheses are credible.
Containment	Fast action can stop lateral movement before the attacker expands.	Auto only for high-confidence, reversible actions.
Post-incident hardening	Find repeated attack paths and exposed controls across the estate.	Risk owner approves durable changes.

What success looks like

- Analysts receive an evidence-backed incident narrative, not 20 isolated alerts.
- Common containment actions execute in seconds under explicit policy.
- The agent shows what evidence it used, what it changed, and why.
- Every action is auditable and reversible where possible.

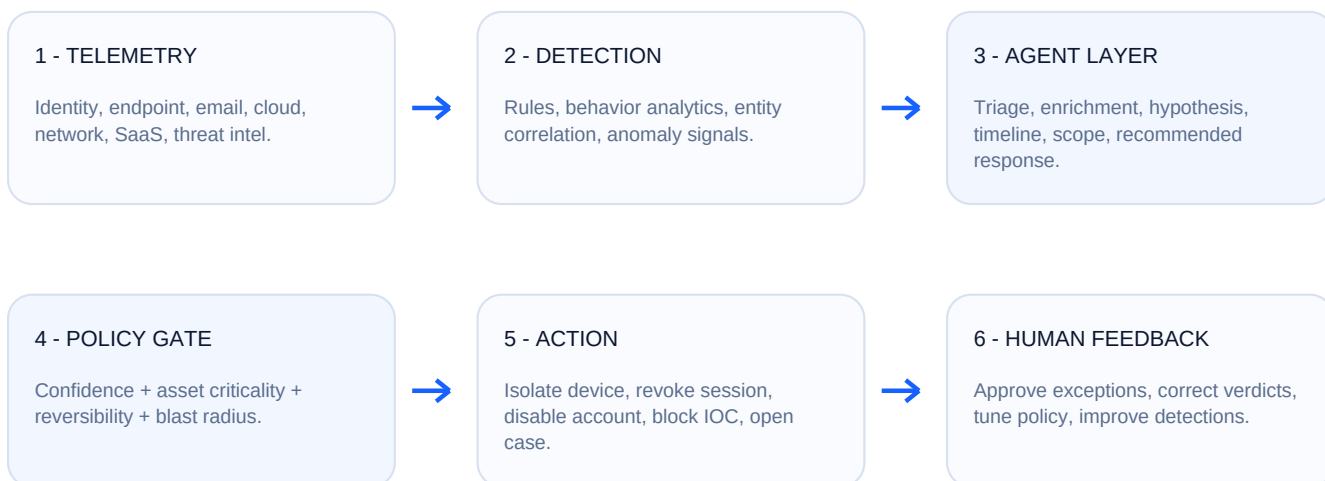
What failure looks like

- A hallucinated verdict triggers destructive remediation.
- Prompt injection manipulates the security agent itself.
- An over-privileged agent becomes a lateral-movement path.
- Automation hides poor telemetry instead of fixing it.

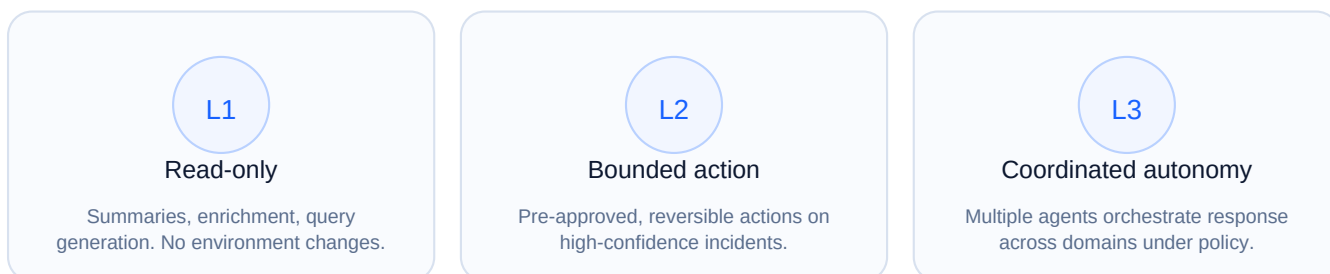
The design target is not maximum autonomy. It is maximum defensible autonomy.

How an agentic SOC should be wired

Autonomy is safest when it sits on top of strong telemetry, deterministic controls, constrained permissions, and explicit escalation rules.



Recommended autonomy ladder



Keep these actions behind human approval

Permanent deletion, domain-wide policy changes, identity privilege changes, high-impact segmentation, public communications, legal/regulatory decisions, or actions where confidence is not independently validated.

Metrics that actually matter



Illustrative KPI direction only; bars are not measured values.

Attackers are already reducing human latency

CASE 01 - GTIG - Q2 2026

Mass credential harvesting in under six hours

Google Threat Intelligence Group observed a financially motivated actor compromise cloud infrastructure, then use an AI coding chatbot plus agent instructions to plan, build and execute an autonomous scanning and credential-harvesting workflow.

The framework handled scanning, troubleshooting and IP rotation with minimal human intervention. GTIG says the campaign compromised thousands of third-party credentials.

[Open original GTIG research ->](#)

WHY IT MATTERS

The response window is compressing

This is not evidence that every attacker is fully autonomous. It is evidence that high-volume work which once needed operators can now be orchestrated by agents.

A defensive team that spends the first hours gathering basic context may be racing an adversary that has already automated reconnaissance, troubleshooting and credential collection.

Earlier incidents show the business cost when identity + operations collide

MGM Resorts - September 2023

MGM disclosed a cybersecurity incident that disrupted U.S. systems and guest-facing operations. In an SEC filing, MGM estimated roughly \$100M of negative impact to adjusted property EBITDAR for the quarter, plus under \$10M in one-time incident expenses.

Octo Tempest / Scattered Spider tradecraft

Microsoft documented a financially motivated cluster that commonly social-engineered support/help-desk staff into password resets or MFA changes, then moved through identity, cloud, code repositories and infrastructure using legitimate channels.

What an agentic SOC could surface earlier

- Help-desk identity reset followed by risky sign-in.
- New MFA method + unusual device + privileged resource access.
- Bulk user/group enumeration after account recovery.
- New cloud/SaaS access from previously unseen infrastructure.
- Security-control tampering correlated with identity events.

These are correlation opportunities, not a claim that AI would have prevented a specific historical incident.

Important: this brief does not claim Microsoft's Octo Tempest report establishes attribution for the MGM incident. The two are presented as separate, relevant examples: one demonstrates business impact; the other documents the type of identity-centric, cross-domain tradecraft a modern SOC must detect quickly.

The defender can become the target

An agent with broad visibility, tool access and response permissions is powerful. That also makes it valuable to an attacker.

Real 2026 example: prompt injection aimed at security analysis

GTIG documented malware containing adversarial text intended to make LLM security scanners fail or skip the malicious JavaScript beneath it. The broader lesson is simple: security agents must treat attacker-controlled content as hostile input.

[Read GTIG's prompt-injection example ->](#)

Primary failure modes

- Prompt injection: malicious content manipulates agent instructions or tool choices.
- Over-privilege: one compromised agent identity has excessive reach.
- Hallucinated causality: plausible narrative is mistaken for verified evidence.
- Automation cascade: one bad verdict triggers downstream actions.
- Data leakage: sensitive telemetry escapes through tools, prompts or logs.

Controls that make autonomy defensible

- Separate agent identities; no shared human credentials.
- Least-privilege tools and resource scopes per agent.
- Policy engine outside the LLM for destructive actions.
- Evidence citations + confidence + reason for every verdict.
- Tamper-resistant audit of prompts, tools, actions and approvals.
- Rate limits, kill switch, rollback path and blast-radius caps.
- Adversarial testing with poisoned alerts and prompt injection.

A useful rule of thumb

Let the model reason. Let deterministic policy decide what it is allowed to change.

This mirrors the strongest current production pattern: high-confidence controls handle known threats automatically; agents handle context and coordination; humans own ambiguous, irreversible or high-consequence decisions.

A practical 90-day path

DAYS 0-30

Foundation

- Unify telemetry.
- Fix identity / asset context.
- Choose one high-volume workflow.
- Start agents read-only.
- Define evaluation set + baseline.

DAYS 31-60

Supervised action

- Add bounded tools.
- Require approval for containment.
- Log every agent action.
- Red-team prompt injection.
- Measure analyst overrides.

DAYS 61-90

Selective autonomy

- Auto-execute reversible actions.
- Use confidence + criticality gates.
- Add rollback / kill switch.
- Expand only after measured reliability.
- Review governance monthly.

Do not measure success by "how many actions the AI took." Measure it by how much trustworthy analyst capacity, containment speed, and risk reduction you gained.

Suggested SOC scorecard

Metric	Why it matters
Mean time to evidence / decision / containment	Shows whether agents actually compress response latency.
Analyst override rate	High overrides expose poor agent accuracy or bad policy thresholds.
False containment rate	Critical safety metric for autonomous response.
% actions with complete evidence + audit trail	Measures explainability and accountability, not just speed.
Repeat-incident / repeat-attack-path rate	Shows whether time saved is converted into hardening.

Primary / authoritative sources

[Microsoft - The agentic SOC \(2026\)](#)

[IBM - Cost of a Data Breach Report 2026](#)

[Microsoft Learn - Phishing Triage Agent](#)

[SEC - MGM Resorts 8-K \(Oct. 2023\)](#)

[Google Cloud - Security Operations agents](#)

[Microsoft Threat Intelligence - Octo Tempest](#)

[Google Threat Intelligence - From Prompting to Autonomy \(2026\)](#)

[Google Security Operations - Investigate](#)

Research note: vendor performance figures describe those vendors' own products/environments and should not be generalized without local testing. Incident examples illustrate operational patterns; no unsupported attribution is implied.